

初始信息收集

先nmap端口扫描



vsftpd 3.0.3没有找到有用的公开漏洞

nmap提示可以匿名访问ftp 两个文件motto.txt pass.txt 其中pass.txt不可读

访问<target>:80



访问<http://hyh.maze-sec.com/> 无响应 dig一下发现DNS解析失败

从web应用RCE

我用的是自建xray代理 本地通过虚拟网卡实现透明代理 只要虚拟机能访问公网 所有公网流量和DNS解析都会经VPS代理

因此可以DNS劫持 只需改VPS的hosts文件即可将域名解析到VPS

由此可以让hyh.maze-sec.com返回php一句话 从而得到www-data的shell

读取pass.txt

先收集本地信息

FTP的pass.txt权限400 所有者hyh 很可疑的文件 :3

并且注意到ll104567是sudo组成员 那么攻击路径就比较清晰了

hyh的任意文件读取->读取pass.txt->hyh的shell->横向移动到ll104567或直接get root

```
<pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
highlight_file</span><span style="color: #007700">(</span><span style="color:
#0000BB">__FILE__</span><span style="color: #007700">);
@include</span><span style="color: #DD0000">"http://hyh.maze-sec.com/"</span><
span style="color: #007700">;
</span></code></pre>hyh      516      515  0 10:08 ?      00:00:00 /bin/s
h -c /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m http.server 8080 -
-bind 127.0.0.1 --directory /var/tmp'
hyh      517      516  0 10:08 ?      00:00:00 /usr/bin/timeout 30s /usr/
bin/python3 -m http.server 8080 --bind 127.0.0.1 --directory /var/tmp
hyh      518      517  0 10:08 ?      00:00:00 /usr/bin/python3 -m http.s
erver 8080 --bind 127.0.0.1 --directory /var/tmp
www-data 519      483  0 10:08 ?      00:00:00 sh -c ps -ef | grep hyh
www-data 521      519  0 10:08 ?      00:00:00 grep hyh
```

一直 ps -ef | grep hyh (上传pspy也行) 发现用户hyh的定时任务

```
python3 -m http.server 8080 --bind 127.0.0.1 --directory /var/tmp
```

通过这个定时任务可以以hyh身份读取/var/tmp中任意文件 尝试利用软链接读取pass.txt

用which探测到本地没有wget和curl 因此通过php file_get_contents请求127.0.0.1:8080/pass.txt

但是读取失败 自己本地测试 发现/var/tmp和/tmp中 用户a不能跟随用户b的软链接 报错权限不够 即使软链接指向的文件具有777权限

询问人工智障 这是linux内核保护机制 fs.protected_symlinks 只要在/var/tmp/创建一个没有sticky bit的文件夹 在其中放置软链接 就可以解决

成功读到pass.txt

```
hyh:HYH4Rly9UF3vwJq+xEK1F53JYaMM
hint:^ma....$
```

Get ROOT

hmm 先ssh爆破 rockyou.txt前5000行所有符合正则的条目


```
mandy[+] 127.0.0.1:10022 - Failed: 'hyh:marsha'
marsha[+] 127.0.0.1:10022 - Failed: 'hyh:maisie'
maisie[+] 127.0.0.1:10022 - Failed: 'hyh:madman'
madman[+] 127.0.0.1:10022 - Failed: 'hyh:mamama'
mamama[+] 127.0.0.1:10022 - Failed: 'hyh:maiden'
maiden[+] 127.0.0.1:10022 - Failed: 'hyh:marvel'
marvel[+] 127.0.0.1:10022 - Failed: 'hyh:magnum'
magnum[+] 127.0.0.1:10022 - Failed: 'hyh:magic1'
magic1[+] 127.0.0.1:10022 - Failed: 'hyh:malena'
malena[+] 127.0.0.1:10022 - Failed: 'hyh:marlen'
marlen[+] 127.0.0.1:10022 - Failed: 'hyh:marlyn'
marlyn[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

```
A msf1auxiliary(scanner/ssh/ssh_login) > |1GiB/26GiB
```

base64转换hex 丢给hashcat判断哈希类型

```
A yepian 23:25 - 2s21ms 4GiB/26GiB
x prime-run hashcat 1d21f846bc7d507abe32b1bd172d45e7725868c3
hashcat (v7.1.2) starting in autodetect mode

nvmlDeviceGetFanSpeed(): Not Supported

CUDA API (CUDA 13.2)
=====
* Device #01: NVIDIA GeForce RTX 5060 Laptop GPU, 7585/7707 MB, 26MCU

OpenCL API (OpenCL 3.0 CUDA 13.2.73) - Platform #1 [NVIDIA Corporation]
=====
* Device #02: NVIDIA GeForce RTX 5060 Laptop GPU, skipped

The following 7 hash-modes match the structure of your input hash:
```

#	Name	Category
100	SHA1	Raw Hash
6000	RIPEMD-160	Raw Hash
170	sha1(utf16le(\$pass))	Raw Hash
4700	sha1(md5(\$pass))	Raw Hash salted and/or iterated
18500	sha1(md5(md5(\$pass)))	Raw Hash salted and/or iterated
4500	sha1(sha1(\$pass))	Raw Hash salted and/or iterated
300	MySQL4.1/MySQL5	Database Server

```
Please specify the hash-mode with -m [hash-mode].

Started: Mon Apr 6 23:25:48 2026
Stopped: Mon Apr 6 23:25:49 2026
```

看上去是SHA1 但是破不出来

折腾了一番 实际上这就是hyh的明文密码 且 ^ma...\$ 是用户ll104567的密码

筛选rockyou中全部符合正则且纯字母数字的条目爆破 得到 mazel1

登陆SSH 直接sudo su 得到root flag